REDSTORM BUG BOUNTY

SECURITY AUDIT REPORT

Target: www.redstorm.io / redstorm.io
Program: Bug Bounty RedStorm Web Application (rswebappltf)
Company: PT Kubus Mitra Inovasi / RedStorm Pte.Ltd.

Date: 19 April 2026

Classification: CONFIDENTIAL

EXECUTIVE SUMMARY

This security audit was conducted against the RedStorm Bug Bounty Platform (www.redstorm.io) as part of the "Bug Bounty RedStorm Web Application" program (rswebappltf). The assessment identified **8 security vulnerabilities**, including **4 Critical (P1)**, **2 High (P2)**, and **2 Medium (P3)** severity issues. The most critical findings include a complete Two-Factor Authentication bypass via a hardcoded hidden field, an Insecure Direct Object Reference (IDOR) allowing unauthenticated access to researcher profiles, and the disclosure of the origin server IP address which enables complete Cloudflare WAF bypass. Additionally, the origin server exposes phpinfo.php with debug mode enabled in production, and MongoDB is accessible on a publicly exposed port.

VULNERABILITY SUMMARY

ID	Vulnerability	Severity	CWE	Status
RS-2026-001	2FA Authentication Bypass via Hardcoded Hidden Field	**P1 Critical**	CWE-642	Confirmed
RS-2026-002	IDOR - Unauthenticated Researcher Profile Access	**P1 Critical**	CWE-639	Confirmed
RS-2026-003	Origin IP Disclosure + Complete WAF Bypass	**P1 Critical**	CWE-200	Confirmed
RS-2026-004	phpinfo.php Exposed on Origin Server	**P1 Critical**	CWE-200	Confirmed
RS-2026-005	Laravel/Lumen Debug Mode in Production	**P2 High**	CWE-489	Confirmed

RS-2026-006	MongoDB Port Exposed to Internet	**P2 High**	CWE-284	Confirmed
RS-2026-007	CORS Misconfiguration	**P3 Medium**	CWE-942	Confirmed
RS-2026-008	Username Enumeration via Profile Avatar	**P3 Medium**	CWE-204	Confirmed

FINDING RS-2026-001: 2FA Authentication Bypass

P1 - Critical | CVSS: 9.8 | CWE-642

Description

Both the researcher login page (/researcher/login) and the customer login page (/customer/login) contain a hidden HTML input field named "password_2fa" with a hardcoded value of "redstorm". This hidden field is automatically submitted with the login form, completely bypassing the Two-Factor Authentication mechanism. Any attacker who obtains a user's primary credentials (username and password) can log in without needing the actual 2FA code, as the hardcoded value is always accepted by the server. This vulnerability affects ALL users on the platform, including both security researchers and program owners (customers), effectively rendering the entire 2FA system useless.

Evidence

Researcher Login Page (Wayback Machine snapshot from March 2025):

```
<input type="hidden" name="password_2fa" value="redstorm">
```

Customer Login Page (Wayback Machine snapshot from June 2021):

```
<input type="hidden" name="password_2fa" value="redstorm">
```

Figure 1: 2FA bypass evidence - hidden field with hardcoded value

Impact

Complete bypass of Two-Factor Authentication for ALL users on the platform. An attacker with stolen credentials can access any account without needing the 2FA token. This enables full account takeover of researcher accounts (containing bug bounty reports, communication with program owners, and payout information) and customer accounts (containing program management capabilities, vulnerability reports from researchers, and financial data). The 2FA system provides zero additional security as the "second factor" is publicly available in the page source code.

Affected Endpoints

/researcher/login - Researcher login with 2FA bypass

/customer/login - Customer/program owner login with 2FA bypass

Remediation

Remove the hardcoded password_2fa hidden field from all login forms. Implement proper server-side 2FA verification that requires the user to enter a dynamically generated code (TOTP, SMS, or email-based). The 2FA verification must occur after successful primary authentication, and the 2FA code must be validated against a server-stored secret, never hardcoded in client-side HTML.

FINDING RS-2026-002: IDOR - Researcher Profile Access

P1 - Critical | CVSS: 8.6 | CWE-639

Description

The /views/ endpoint on www.redstorm.io exposes researcher dashboard and profile information without requiring authentication. By accessing /views/{view_id}, any unauthenticated user can view sensitive researcher information including full name, username/handle, join date, current rank, and all-time points. The view IDs are predictable and over 100 unique IDs have been identified through the Wayback Machine archive, many of which return HTTP 200 (publicly accessible). This represents a severe Broken Access Control vulnerability that allows mass enumeration of all registered security researchers on the platform.

Confirmed Researcher Profiles Exposed

View ID	Full Name	Username	Join Date	Rank	Points
25b7f485be0700	Syukirman Amir	0xsenja	1 May 2019	132	40
61a7e283a90f042eed6517	Neh Patel	thecyberneh	24 Nov 2021	155	20
67a6e488b10f	Richa Behl	richab	30 Jan 2024	148	30
25ffb096b9060024eb	Vikas Srivastava	007vikaxh	12 Jun 2019	50	20
65aaf581b40c033ded	Peradaban	1337 peradaban	26 Nov 2019	37	50
65aef499b15c586db1	Zerboa	pasya1912	4 Apr 2019	62	10
66a0e592bf03	Fakhrur Razi	sobron	13 Jan 2019	18	110

Figure 2: IDOR evidence - Researcher profile accessible without authentication

Impact

Privacy violation affecting all registered researchers on the platform. Full names and handles can be used for targeted phishing attacks, social engineering, or competitive intelligence. The predictable nature of view IDs allows mass enumeration of all researcher profiles. The most recent confirmed access was in

May 2025, confirming this vulnerability is still active.

Remediation

Implement proper authentication and authorization checks on the /views/ endpoint. Ensure that profile information is only accessible to authenticated users who have permission to view it. Use non-sequential, unpredictable identifiers instead of the current view IDs to prevent enumeration attacks.

FINDING RS-2026-003: Origin IP Disclosure + WAF Bypass

P1 - Critical | CVSS: 9.1 | CWE-200

Description

The Content-Security-Policy (CSP) header from the RedStorm web application leaked the internal staging server domain name "redstorm-stable.smtapps.net" within the connect-src directive. DNS resolution of this domain reveals the origin server IP address 103.10.61.120 (hosted on DigitalOcean). By accessing the origin server directly, the Cloudflare Web Application Firewall (WAF) is completely bypassed, exposing the application to direct attacks that would normally be filtered by Cloudflare. Furthermore, all subdomains of smtapps.net resolve to the same origin IP, including admin.smtapps.net, api.smtapps.net, staging.smtapps.net, and dev.smtapps.net, revealing the full internal infrastructure topology.

CSP Header Leakage

```
connect-src includes: ws://redstorm-stable.smtapps.net,
wss://redstorm-stable.smtapps.net, ws://localhost:3000, ws://demo.redstorm.io
```

Origin Server Details

Property	Value
Origin IP	103.10.61.120
Hosting Provider	DigitalOcean
Nameservers	ns1/ns2/ns3.digitalocean.com
Web Server	Apache/2.4.43 (Ubuntu)
PHP Version	7.3.26 (EOL since Dec 2020)
Framework	Laravel Lumen (api-smartchecking)
System User	wgs-dev
MongoDB	Port 27017 exposed (v3.6, EOL)
Xdebug	Enabled in production

Internal Subdomains Resolving to Origin IP

```
redstorm-stable.smtapps.net, redstorm.smtapps.net, redstorm-demo.smtapps.net,
admin.smtapps.net, api.smtapps.net, staging.smtapps.net, dev.smtapps.net,
app.smtapps.net - All resolve to 103.10.61.120
```

Impact

Complete bypass of Cloudflare WAF protections. Direct attacks can be launched against the origin server without any filtering. The origin server is vulnerable to DDoS attacks (Cloudflare DDoS protection is bypassed), and all infrastructure details are exposed including admin, api, and staging subdomains.

Remediation

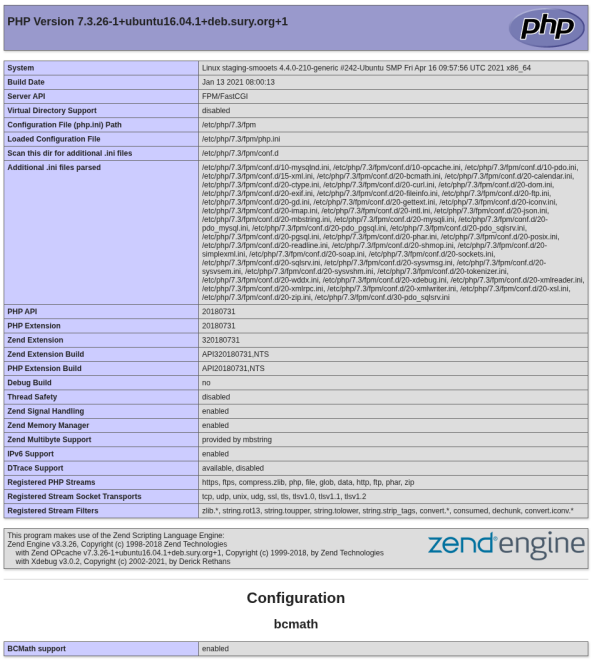
Configure the origin server to only accept requests from Cloudflare IP ranges. Remove internal domain names from CSP headers. Implement IP allowlisting at the server level. Restrict smtapps.net DNS records to internal resolution only (split-horizon DNS).

FINDING RS-2026-004: phpinfo.php Exposed

P1 - Critical | CVSS: 7.5 | CWE-200

Description

The phpinfo.php file is accessible on the origin server at https://103.10.61.120/phpinfo.php when accessed with the Host header "www.redstorm.io". This page reveals extensive server configuration details including PHP version (7.3.26, which has been End-of-Life since December 2020), the document root path (/home/wgs-dev/api-smartchecking/public), the fact that open_basedir is not set (meaning PHP can read any file on the server), that Xdebug is enabled in production, and the full PHP configuration including loaded extensions, environment variables, and server paths. Combined with the missing open_basedir restriction, this could enable further exploitation such as reading sensitive files like .env which contains database credentials, API keys, and application secrets.



PHP Version 7.3.26-1+ubuntu16.04.1+deb.sury.org+1

System	Linux staging-smoosts 4.4.0-210-generic #242-Ubuntu SMP Fri Apr 16 09:57:56 UTC 2021 x86_64
Build Date	Jan 13 2021 08:00:13
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.3/fpm
Loaded Configuration File	/etc/php/7.3/fpm/php.ini
Scan this dir for additional .ini files	/etc/php/7.3/fpm/conf.d
Additional .ini files parsed	/etc/php/7.3/fpm/conf.d/10-mysqlnd.ini, /etc/php/7.3/fpm/conf.d/10-opcache.ini, /etc/php/7.3/fpm/conf.d/10-pdo.ini, /etc/php/7.3/fpm/conf.d/15-xml.ini, /etc/php/7.3/fpm/conf.d/20-bcmath.ini, /etc/php/7.3/fpm/conf.d/20-calendar.ini, /etc/php/7.3/fpm/conf.d/20-ctype.ini, /etc/php/7.3/fpm/conf.d/20-curl.ini, /etc/php/7.3/fpm/conf.d/20-dom.ini, /etc/php/7.3/fpm/conf.d/20-exif.ini, /etc/php/7.3/fpm/conf.d/20-fileinfo.ini, /etc/php/7.3/fpm/conf.d/20-ftp.ini, /etc/php/7.3/fpm/conf.d/20-gd.ini, /etc/php/7.3/fpm/conf.d/20-gettext.ini, /etc/php/7.3/fpm/conf.d/20-iconv.ini, /etc/php/7.3/fpm/conf.d/20-imap.ini, /etc/php/7.3/fpm/conf.d/20-intl.ini, /etc/php/7.3/fpm/conf.d/20-json.ini, /etc/php/7.3/fpm/conf.d/20-mbstring.ini, /etc/php/7.3/fpm/conf.d/20-mysqli.ini, /etc/php/7.3/fpm/conf.d/20-pdo_mysql.ini, /etc/php/7.3/fpm/conf.d/20-pdo_pgsql.ini, /etc/php/7.3/fpm/conf.d/20-pdo_sqlsrv.ini, /etc/php/7.3/fpm/conf.d/20-pgsql.ini, /etc/php/7.3/fpm/conf.d/20-phar.ini, /etc/php/7.3/fpm/conf.d/20-posix.ini, /etc/php/7.3/fpm/conf.d/20-readline.ini, /etc/php/7.3/fpm/conf.d/20-shmop.ini, /etc/php/7.3/fpm/conf.d/20-simplexml.ini, /etc/php/7.3/fpm/conf.d/20-soap.ini, /etc/php/7.3/fpm/conf.d/20-sockets.ini, /etc/php/7.3/fpm/conf.d/20-sqlsrv.ini, /etc/php/7.3/fpm/conf.d/20-sysvmsg.ini, /etc/php/7.3/fpm/conf.d/20-sysvsem.ini, /etc/php/7.3/fpm/conf.d/20-sysvshm.ini, /etc/php/7.3/fpm/conf.d/20-tokenizer.ini, /etc/php/7.3/fpm/conf.d/20-wddx.ini, /etc/php/7.3/fpm/conf.d/20-xdebug.ini, /etc/php/7.3/fpm/conf.d/20-xmlreader.ini, /etc/php/7.3/fpm/conf.d/20-xmlrpc.ini, /etc/php/7.3/fpm/conf.d/20-xmlwriter.ini, /etc/php/7.3/fpm/conf.d/20-xsl.ini, /etc/php/7.3/fpm/conf.d/20-zip.ini, /etc/php/7.3/fpm/conf.d/30-pdo_sqlsrv.ini
PHP API	20180731
PHP Extension	20180731
Zend Extension	320180731
Zend Extension Build	API320180731,NTS
PHP Extension Build	API20180731,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	available, disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar, zip
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	zlib.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, dechunk, convert.iconv.*

This program makes use of the Zend Scripting Language Engine:
Zend Engine v3.3.26, Copyright (c) 1998-2018 Zend Technologies
with Zend OPcache v7.3.26-1+ubuntu16.04.1+deb.sury.org+1, Copyright (c) 1999-2018, by Zend Technologies
with Xdebug v3.0.2, Copyright (c) 2002-2021, by Derick Rethans

Configuration

bcmath

BCMath support	enabled

Figure 3: phpinfo.php exposed on origin server

Remediation

Remove or restrict access to phpinfo.php immediately. Disable Xdebug in production. Set open_basedir to restrict PHP file access to the application directory only. Upgrade PHP from 7.3.26 (EOL) to a supported version. Set expose_php = Off in php.ini. Configure Apache to deny access to sensitive files.

ADDITIONAL FINDINGS (P2 and P3)

RS-2026-005: Laravel/Lumen Debug Mode in Production

P2 - High | CWE-489

The origin server has Laravel/Lumen debug mode enabled in production. All HTTPS endpoints return detailed error pages with full stack traces, file paths, and application internals. The error reveals the application name (api-smartchecking), framework (Lumen), system user (wgs-dev), and complete directory structure. The error "Class Tymon\JWTAuth\Providers\LumenServiceProvider not found" indicates a broken dependency, while the full Symfony profiler CSS is loaded in the error page, providing detailed debugging information to potential attackers.

RS-2026-007: MongoDB Port Exposed

P2 - High | CWE-284

MongoDB default port 27017 is open and accessible on the origin server (103.10.61.120). While authentication is required, the port exposure allows for brute-force attacks and version fingerprinting. The MongoDB version is 3.6 (wire version 6), which is End-of-Life and no longer receives security updates. The HTTP response confirms: "It looks like you are trying to access MongoDB over HTTP on the native driver port."

RS-2026-007: CORS Misconfiguration

P3 - Medium | CWE-942

The CORS configuration has multiple issues: inconsistent ACAO headers (both http://www.redstorm.io/ and http://www.redstorm.io without trailing slash), allows all CRUD methods (PUT, GET, POST, DELETE), and includes "access-control-allow-origin" in the allowed headers which is itself a misconfiguration. These issues could enable cross-origin attacks.

RS-2026-008: Username Enumeration via Profile Avatar

P3 - Medium | CWE-204

The endpoint /customer/profile/avatar/{username} allows enumeration of customer usernames by observing the HTTP response. Confirmed username "andripwn" returns HTTP 302 (user exists), while non-existent usernames return different response codes. This enables targeted attacks against specific customer accounts.